OAuth — Open Authorization

@kamranahmedse

Open protocol for authorization that allows users to share their private resources to a third party

Some examples

- Authorizing your app's frontend from your API
  - Your custom OAuth Server where users of your website get authorized using OAuth.
- Allowing some application to log you in using twitter
  - Exposing your twitter info to an external application using twitter's OAuth server.

There are two Versions

- OAuth 1.0 — deprecated
- OAuth 2.0 — active (Not backward compatible)
- OAuth 2.1 — draft

How does it work?

There are 4 types of authorization flows for generating a token.

Also called **grant types**

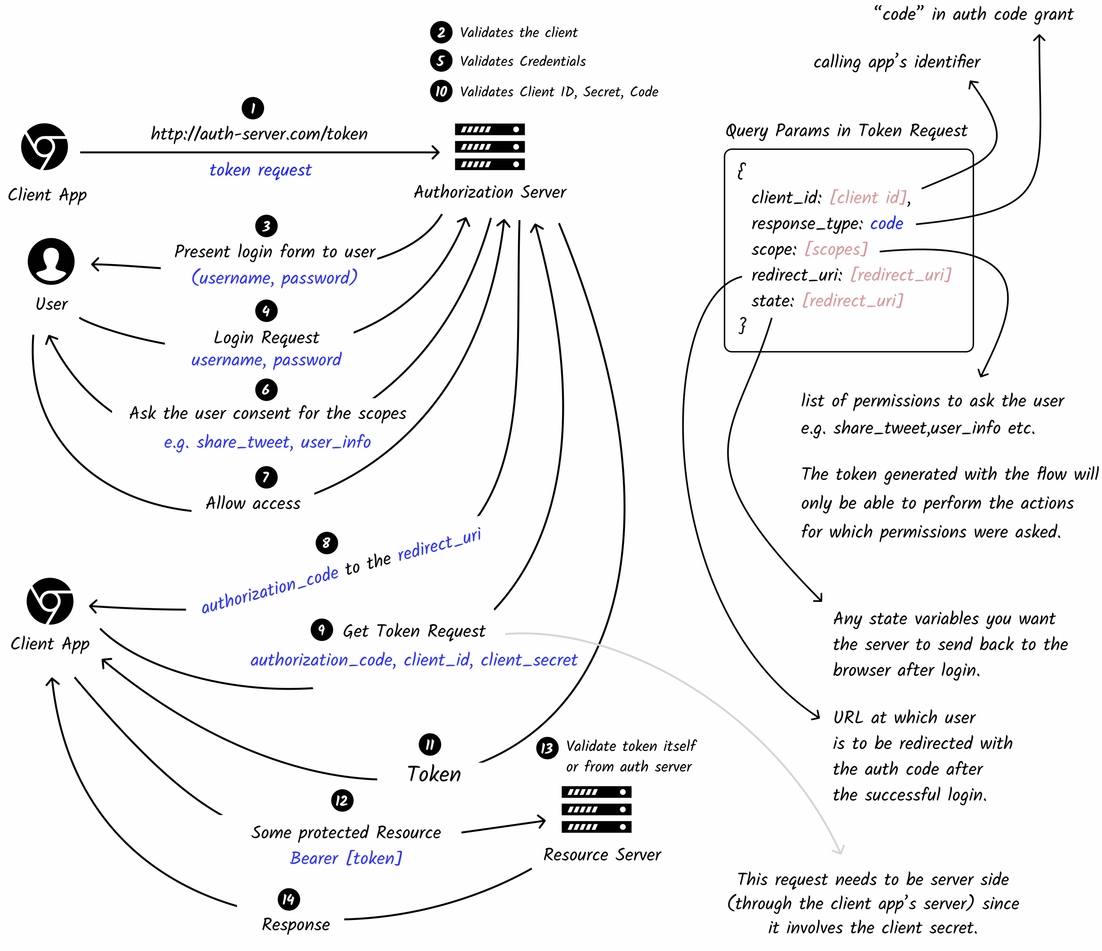
All flows lead to a token which client uses to access protected resource.

1 Authorization Code Grant Flow

Terminology

client_id	-> Like a username for your app
client_secret	-> Like a password for your app
authorization server	-> server that handles authentication and authorization
resource server	-> server that exposes protected resources

-> They could both be a single server also



2 Implicit Grant Flow

Similar to the "Authorization Code Grant Flow" but **in step 8 there is a token instead of authorization code**.
So no need for 9, 10, and 11 steps. Also in the token request the **response_type parameter is set to token instead of code**

3 Client Credential Grant Flow

Similar to the "Authorization Code Grant Flow" but there is no user interaction. It starts at **step 9 and immediately gets the token.**
So step 9 would be step 1 in this grant flow. Also in the **request at step 9 there is no authorization_code and an additional parameter of the grant_type set to token**

4 Password Grant Flow

Similar to the "Authorization Code Grant Flow" but user enters the credentials owned by the the authorization server instead of the app.
So **step 4 to 8 are replaced by the get token request (i.e. step 9) and the credentials are directly sent to the authorization server along with an additional parameter of the grant_type set to password.**

Note

Token response in all grant types is normally accompanied by an expiry date for the token and a refresh token which is used to refresh the token when expired.